Testing for Weak lock out mechanism (OTG-AUTHN-003)

From OWASP

This article is part of the new OWASP Testing Guide v4.

Back to the OWASP Testing Guide v4 ToC:
https://www.owasp.org/index.php/OWASP_Testing_Guide_v4_Table_of_Contents
Back to the OWASP Testing Guide Project:
https://www.owasp.org/index.php/OWASP_Testing_Project

- 1 Summary
- 2 Test objectives
- 3 How to Test
- 4 References
- 5 Remediation

Summary

Account lockout mechanisms are used to mitigate brute force password guessing attacks. Accounts are typically locked after 3 to 5 unsuccessful login attempts and can only be unlocked after a predetermined period of time, via a self-service unlock mechanism, or intervention by an administrator. Account lockout mechanisms require a balance between protecting accounts from unauthorized access and protecting users from being denied authorized access.

Note that this test should cover all aspects of authentication where lockout mechanisms would be appropriate, e.g. when the user is presented with security questions during forgotten password mechanisms (see Testing for Weak security question/answer (OTG-AUTHN-008)).

Without a strong lockout mechanism, the application may be susceptible to brute force attacks. After a successful brute force attack, a malicious user could have access to:

- Confidential information or data: Private sections of a web application could disclose confidential documents, users' profile data, financial information, bank details, users' relationships, etc.
- Administration panels: These sections are used by webmasters to manage (modify, delete, add) web application content, manage user provisioning, assign different privileges to the users, etc.
- Opportunities for further attacks: authenticated sections of a web application could contain vulnerabilities that are not present in the public section of the web application and could contain advanced functionality that is not available to public users.

Test objectives

1. Evaluate the account lockout mechanism's ability to mitigate brute force password guessing.
2. Evaluate the unlock mechanism's resistance to unauthorized account unlocking.

How to Test

Typically, to test the strength of lockout mechanisms, you will need access to an account that you are willing or can afford to lock. If you have only one account with which you can log on to the web application, perform this test at the end of you test plan to avoid that you cannot continue your testing due to a locked account.

To evaluate the account lockout mechanism's ability to mitigate brute force password guessing, attempt an invalid log in by using the incorrect password a number of times, before using the correct password to verify that the account was locked out. An example test may be as follows:

1. Attempt to log in with an incorrect password 3 times.
2. Successfully log in with the correct password, thereby showing that the lockout mechanism doesn't trigger after 3 incorrect authentication attempts.
3. Attempt to log in with an incorrect password 4 times.
4. Successfully log in with the correct password, thereby showing that the lockout mechanism doesn't trigger after 4 incorrect authentication attempts.
5. Attempt to log in with an incorrect password 5 times.
6. Attempt to log in with the correct password. The application returns "Your account is locked out.", thereby confirming that the account is locked out after 5 incorrect authentication attempts.
7. Attempt to log in with the correct password 5 minutes later. The application returns "Your account is locked out.", thereby showing that the lockout mechanism does not automatically unlock after 5 minutes.
8. Attempt to log in with the correct password 10 minutes later. The application returns "Your account is locked out.", thereby showing that the lockout mechanism does not automatically unlock after 10 minutes.
9. Successfully log in with the correct password 15 minutes later, thereby showing that the lockout mechanism automatically unlocks after a 10 to 15 minute period.

A CAPTCHA may hinder brute force attacks, but they can come with their own set of weaknesses (see Testing for CAPTCHA), and should not replace a lockout mechanism.

To evaluate the unlock mechanism's resistance to unauthorized account unlocking, initiate the unlock mechanism and look for weaknesses. Typical unlock mechanisms may involve secret questions or an emailed unlock link. The unlock link should be a unique one-time link, to stop an attacker from guessing or replaying the link and performing brute force attacks in batches. Secret questions and answers should be strong (see Testing for Weak Security Question/Answer).

Note that an unlock mechanism should only be used for unlocking accounts. It is not the same as a password recovery mechanism.

Factors to consider when implementing an account lockout mechanism:

1. What is the risk of brute force password guessing against the application?
2. Is a CAPTCHA sufficient to mitigate this risk?
3. Is a client-side lockout mechanism being used (e.g., Javascript)? (If so, disable the client-side code to test.)
4. Number of unsuccessful log in attempts before lockout. If the lockout threshold is to low then valid users may be locked out too often. If the lockout threshold is to high then the more attempts an attacker can

make to brute force the account before it will be locked. Depending on the application's purpose, a range of 5 to 10 unsuccessful attempts is typical lockout threshold.

5. How will accounts be unlocked?
    1. Manually by an administrator: this is the most secure lockout method, but may cause inconvenience to users and take up the administrator's "valuable" time.
        1. Note that the administrator should also have a recovery method in case his account gets locked.
        2. This unlock mechanism may lead to a denial-of-service attack if an attacker's goal is to lock the accounts of all users of the web application.
    2. After a period of time: What is the lockout duration? Is this sufficient for the application being protected? E.g. a 5 to 30 minute lockout duration may be a good compromise between mitigating brute force attacks and inconveniencing valid users.
    3. Via a self-service mechanism: As stated before, this self-service mechanism must be secure enough to avoid that the attacker can unlock accounts himself.

References

See the OWASP article on Brute Force Attacks.

Remediation

Apply account unlock mechanisms depending on the risk level. In order from lowest to highest assurance:

1. Time-based lockout and unlock.
2. Self-service unlock (sends unlock email to registered email address).
3. Manual administrator unlock.
4. Manual administrator unlock with positive user identification.

Retrieved from "https://www.owasp.org/index.php?title=Testing_for_Weak_lock_out_mechanism_(OTG-AUTHN-003)&oldid=194147"

Categories: OWASP Testing Project | Test

- This page was last modified on 28 April 2015, at 13:39.
- Content is available under Creative Commons Attribution-ShareAlike unless otherwise noted.
-
- Open Web Application Security Project, OWASP, Global AppSec, AppSec Days, AppSec California, SnowFROC, LASCON, and the OWASP logo are trademarks of the OWASP Foundation.